CO1 - AT3

Assessment

Shaik. Thaheer

192425347

Ethical Boundaries of Social Engineering Tests and Psychological Impact on staff :-

Introduction :-

Social Engineering is a cybersecurity technique in which attackers manipulate people into revealing confidential information, clicking malicious links, sharing passwords or performing unsafe actions. Organizations often conduct social Engineering awareness tests to determine whether employees can recognize & respond to phishing attacks.

* The Test may produce a high click rate, the goal of security awareness should be to educate employees and improve security behaviour, not to cause unnecessary fear..

1. purpose of social Engineering Testing :-

* Measure employee awareness of cybersecurity threats.
* Identify weaknesses in security practices.
* Teach employees how to recognize phishing attempts.
* Improve organizational security.

2. Ethical Boundaries of phishing simulations :-

There must be clear limits on what an organization is allowed to do during an awareness test.

(a) obtain propel authorization :-

The testing team should define:

* what Employees will be tested.
* what type of phishing messages will be used.
* How long the test will run.
* who can access results.

(b) Avoid Excessive Emotional manipulation :-

Security tests should not deliberately cause severe Emotional distress. A fake layoff announcement is particularly sensitive because Employees may have financial responsibilities, & concerns about their careers.

(c) Do not Exploit personal vulnerabilities :-

* Medical problems.
* Family Emergencies.
* Death of relative.
* pregnancy.
* Realationship problems.
* Mental health.

3. Psychological Impact of a Fake Layoff Email :-

* Fear and anxiety.
* Loss of trust
  i) Management
  ii) Human Resources.
  iii) security teams.
* Reduced Morale
* workplace stress.
* Feeling of humiliation.

4. Balancing Realism and Ethics :-

A social Engineering test should be realistic enough to measure Employee awaleness but not so Extreme that it causes unnecessary harm.

5) Infolmed Consent & Transpalency :-

If Employees ale infolmed in advance that organizatio conducts peliodic security-awaleness, the organization can maintain a reasonable level of transpalency without revealing Exact timing of Evely test.

* Revealing the Exact date and the Email Content beyole hand could make the test ineffective.

6. IMMEDIATE DEBRIEFING AND TRAINING:-

warning signs may include:-
* unexpected urgent requests.
* suspicious sender addresses.
* unusual links.
* Requests for passwords.
* Threatening language.
* poor glammar.

7) Avoid punitive Actions:-

Employees should generally not be punished simply for failing phishing simulation.

A better approach is:
Identify → Educate → Retrain → Retest.

Ex:-
1. Employee clicks the simulated phishing link.
2. The system records event.
3. The Employee receives a short awareness lession.
4. A later simulation measures improvement.

This creates a positive security culture.